

INFORME DE PENTESTING

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. | Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Universidad Champagnat
Docente: Ing. Rodrigo Atilio Elgueta

Contratista: Maure Spinelli, Juan Manuel
Username TryHackMe: juanchomaure1

1. Datos generales

Cliente	INSECUR S.A.
Contratista (alumno/a)	Maure Spinelli, Juan Manuel
DNI	44.904.602
Username TryHackMe	juanchomaure1
Email institucional	juanmaure123@outlook.com
Sala de elección (Nivel 2)	Nmap
Branch en GitHub	maure-juan
Fecha de inicio	01/10/2026
Fecha de cierre	08/10/2026

Salas trabajadas

Nivel	Sala	Tipo	Estado
Núcleo	Pentesting Fundamentals	Teórica	Completada
Núcleo	Basic Pentesting	Práctica	Completada
Elección	Nmap	Práctica	Completada

2. Pre-pentesting

2.1 Alcance del trabajo

Dentro del alcance: únicamente las máquinas virtuales de TryHackMe asignadas en esta actividad (Basic Pentesting y Nmap), accedidas mediante la VPN oficial de la plataforma y solo contra la dirección IP asignada a cada sesión de trabajo.

Fuera del alcance: cualquier otro sistema, red o servicio, incluyendo la infraestructura propia de TryHackMe ajena a las máquinas desplegadas, la red de la facultad y cualquier sistema real o de terceros.

2.2 Reglas de enfrentamiento (ROE)

- Objetivos permitidos: solo la IP asignada por TryHackMe durante la sesión activa (las máquinas se red despliegan y cambian de IP entre sesiones).
- Técnicas permitidas: escaneo, enumeración, explotación y escalada de privilegios propias de cada sala.
- Técnicas restringidas: fuerza bruta (Hydra) únicamente contra el servicio y usuario indicados por la sala, con límites de hilos y wordlist.
- Técnicas prohibidas: denegación de servicio y ataques contra la plataforma, otros usuarios o sistemas fuera de alcance.
- Límites de tráfico: escaneos con tasas moderadas, sin saturar el objetivo.
- Ante un incidente: detener la actividad, documentar lo ocurrido e informar al docente.
- Datos sensibles: bitácoras revisadas para quitar secretos; credenciales reportadas solo como hash SHA-256.

2.3 Autorización

Declaro que cuento con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (Universidad Champagnat) para realizar pruebas de penetración sobre los entornos de laboratorio de TryHackMe indicados en la guía de la Actividad A08, con fines exclusivamente académicos.

2.4 Metodología utilizada

Marco adoptado: PTES (Penetration Testing Execution Standard). PTES describe una intervención de pentesting de principio a fin, desde los acuerdos previos hasta la entrega del informe, lo que coincide con la estructura de esta actividad: documentación previa, durante y posterior a la intervención, más un protocolo de contingencia. Sus fases se aplicaron directamente a las máquinas de TryHackMe, asociando cada hallazgo a la fase en la que fue descubierto. Como PTES no define una escala de severidad propia, se complementó con CVSS para estimar la criticidad de cada hallazgo y con categorías OWASP/CWE para clasificarlos.

Fase	Aplicación en este trabajo
Preenganche	Secciones de alcance, ROE y autorización de este informe
Reconocimiento y escaneo	Verificación de conectividad (ping) y descubrimiento de puertos, servicios y directorios web con Nmap y Gobuster
Enumeración	Análisis del contenido web expuesto (dev.txt / j.txt), confirmación de usuario válido por SSH, verificación de login FTP anónimo
Explotación	Ataque de contraseñas con Hydra (diccionario rockyou.txt) contra el usuario jan por SSH
Postexplotación	Enumeración local tras el acceso inicial; obtención y crackeo con John the Ripper de la clave SSH privada del usuario kay; acceso al archivo pass.bak
Reporte	Hallazgos, recomendaciones y protocolo de contingencia

3. Hallazgos por fase

3.1 Pentesting Fundamentals

Sala teórica: no genera hallazgos técnicos. Aporta el marco metodológico aplicado en la sección 2.4.
Evidencia de finalización: evidencias/reconocimiento/salas_completadas_perfil.png

3.2 Basic Pentesting

Host objetivo: 10.66.180.147 (IP asignada en la sesión de trabajo; cambia en cada redespiegue de la máquina).

Hallazgo H-01

ID del hallazgo	H-01
Sala	Basic Pentesting
Fase	[X] Reconocimiento [X] Escaneo [] Enumeración [] Explotación [] Postexplotación
Descripción	Un escaneo de puertos con Nmap reveló 5 servicios de interés: SSH (22) y HTTP (80) abiertos, y el servicio SMB (139/445) abierto; el puerto FTP (21) aparece cerrado. La superficie expuesta (SSH + HTTP + SMB) resultó suficiente para iniciar la cadena de ataque completa descrita en los hallazgos siguientes.
Componente afectado	Servidor objetivo — servicios SSH, HTTP y SMB (puertos 22, 80, 139, 445)

Categoría (OWASP / CWE)	A05:2021 – Security Misconfiguration / CWE-200 (Information Exposure)
CVE (si aplica)	No aplica
CVSS estimado	[X] Bajo [] Medio [] Alto [] Crítico Puntaje: 3.1
Evidencia	evidencias/escaneo/01_basicpentesting_nmap.png
Herramienta utilizada	Nmap
Impacto en la Tríada CIA	[X] Confidencialidad [] Integridad [] Disponibilidad
Salvaguarda propuesta	Exponer únicamente los servicios estrictamente necesarios y filtrar con firewall perimetral los puertos administrativos (SMB) a redes no confiables.
Riesgo residual tras aplicar	[X] Bajo [] Medio [] Alto

Hallazgo H-02

ID del hallazgo	H-02
Sala	Basic Pentesting
Fase	[] Reconocimiento [X] Escaneo [X] Enumeración [] Explotación [] Postexplotación
Descripción	La enumeración de directorios web con Gobuster reveló la ruta /development/ con listado de Apache habilitado, exponiendo dos archivos de texto internos: dev.txt (bitácora del administrador) y j.txt (nota de un compañero avisando que auditó /etc/shadow y 'crackeó fácilmente' la contraseña de un usuario, recomendando cambiarla). Esta información funcionó como pista directa para el ataque de fuerza bruta del hallazgo H-03.
Componente afectado	Apache httpd 2.4.41, directorio /development/ (puerto 80)
Categoría (OWASP / CWE)	A01:2021 – Broken Access Control / CWE-548 (Exposure of Information Through Directory Listing)
CVE (si aplica)	No aplica
CVSS estimado	[] Bajo [X] Medio [] Alto [] Crítico Puntaje: 5.3
Evidencia	evidencias/escaneo/02_development_listado.png, evidencias/escaneo/03_dev_j_contenido.png
Herramienta utilizada	Gobuster, curl, wget
Impacto en la Tríada CIA	[X] Confidencialidad [] Integridad [] Disponibilidad
Salvaguarda propuesta	Deshabilitar el listado de directorios (Options -Indexes) y retirar archivos de notas internas del document root público.
Riesgo residual tras aplicar	[X] Bajo [] Medio [] Alto

Hallazgo H-03

ID del hallazgo	H-03
Sala	Basic Pentesting

Fase	☐ Reconocimiento ☐ Escaneo ☐ Enumeración ☒ Explotación ☐ Postexplotación
Descripción	A partir de la pista obtenida en H-02 (contraseña débil de un usuario), se realizó un ataque de diccionario con Hydra contra el servicio SSH usando el usuario jan y una wordlist derivada de rockyou.txt. El ataque encontró la contraseña válida armando en pocos minutos, confirmando una política de contraseñas débil. Con las credenciales obtenidas se logró acceso inicial por SSH como jan, sin privilegios de administrador (sudo -l no mostró permisos).
Componente afectado	OpenSSH (puerto 22), cuenta de usuario jan
Categoría (OWASP / CWE)	A07:2021 – Identification and Authentication Failures / CWE-521 (Weak Password Requirements)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico Puntaje: 7.5
Evidencia	evidencias/explotacion/04_hydra_login_jan_armando.png, evidencias/explotacion/05_ssh_login_jan.png
Herramienta utilizada	Hydra, rockyou.txt (wordlist acotada para la prueba), ssh
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Forzar una política de contraseñas robusta, implementar autenticación por clave pública en lugar de contraseña, y limitar los intentos de login (fail2ban) para mitigar ataques de fuerza bruta.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-04

ID del hallazgo	H-04
Sala	Basic Pentesting
Fase	☐ Reconocimiento ☐ Escaneo ☐ Enumeración ☐ Explotación ☒ Postexplotación
Descripción	Con acceso como jan, la enumeración del sistema (ls /home, sudo -l, find con bit SUID, uname -a) no reveló vectores de escalada directos, pero sí un segundo usuario del sistema (kay) con un archivo pass.bak y una carpeta .ssh con permisos abiertos (755). Dentro de esa carpeta, la clave privada id_rsa de kay tenía permisos de lectura abiertos (644), permitiendo a cualquier usuario del sistema copiarla.
Componente afectado	/home/kay/.ssh/id_rsa (permisos 644), /home/kay (permisos 755)
Categoría (OWASP / CWE)	A01:2021 – Broken Access Control / CWE-522 (Insufficiently Protected Credentials)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico Puntaje: 7.1
Evidencia	evidencias/explotacion/06_home_kay_listado.png, evidencias/explotacion/07_enumeracion_privesc.png, evidencias/explotacion/08_kay_ssh_private_key.png
Herramienta utilizada	ls, sudo -l, find, inspección manual de permisos

Impacto en la Tríada CIA	[X] Confidencialidad [] Integridad [] Disponibilidad
Salvaguarda propuesta	Restringir los permisos de archivos de claves privadas a solo su propietario (chmod 600) y auditar periódicamente permisos de directorios home.
Riesgo residual tras aplicar	[] Bajo [X] Medio [] Alto

Hallazgo H-05

ID del hallazgo	H-05
Sala	Basic Pentesting
Fase	[] Reconocimiento [] Escaneo [] Enumeración [] Explotación [X] Postexplotación
Descripción	Se copió la clave privada filtrada de kay (H-04) y se crackeó su passphrase con John the Ripper usando rockyou.txt, obteniendo acceso SSH como kay. Dentro de su home se encontró el archivo pass.bak con una contraseña en texto plano, logrando el compromiso total de las credenciales del sistema a partir de una cadena de fallas simples.
Componente afectado	Clave privada /home/kay/.ssh/id_rsa, archivo /home/kay/pass.bak
Categoría (OWASP / CWE)	A02:2021 – Cryptographic Failures / CWE-256 (Plaintext Storage of a Password)
CVE (si aplica)	No aplica (mala práctica / configuración)
CVSS estimado	[] Bajo [] Medio [] Alto [X] Crítico Puntaje: 9.1
Evidencia	evidencias/explotacion/09_scp_crack_kay_passphrase.png, evidencias/explotacion/10_pass_bak_final_password.png
Herramienta utilizada	scp, ssh2john, John the Ripper (rockyou.txt), ssh
Impacto en la Tríada CIA	[X] Confidencialidad [X] Integridad [] Disponibilidad
Salvaguarda propuesta	No almacenar contraseñas en texto plano, exigir passphrases robustas en todas las claves privadas y rotar de inmediato las credenciales comprometidas.
Riesgo residual tras aplicar	[] Bajo [X] Medio [] Alto (requiere rotación inmediata de credenciales)

Nota metodológica — TCP Connect scan: se verificó el comportamiento de un escaneo TCP Connect (-sT) contra el puerto 80 capturando el tráfico con Wireshark, confirmando el 3-way handshake completo (SYN → SYN/ACK → ACK) típico de este tipo de escaneo, a diferencia del SYN scan (-sS) que no completa la conexión. Evidencia: evidencias/escaneo/11_wireshark_tcp_connect_puerto80.png

3.3 Nmap (sala de elección, Nivel 2)

Host objetivo: IP asignada dinámicamente por TryHackMe en cada red despliegue de la máquina (10.65.150.223 en la corrida documentada en este informe).

Hallazgo H-06

ID del hallazgo	H-06
Sala	Nmap

Fase	☐ Reconocimiento ☒ Escaneo ☐ Enumeración ☐ Explotación ☐ Postexplotación
Descripción	El host objetivo no responde a ICMP echo (ping), indicando un firewall que bloquea el descubrimiento por ICMP. Sin embargo, un escaneo Xmas (-sX) y un escaneo SYN (-sS -Pn) con Nmap revelaron 5 puertos TCP abiertos: 21/ftp, 53/domain, 80/http, 135/msrpc y 3389/ms-wbt-server (RDP), evidenciando una superficie de ataque considerable para un host que, ante un ping simple, aparenta estar inalcanzable.
Componente afectado	Host objetivo (IP asignada por TryHackMe), servicios FTP, DNS, HTTP, MSRPC y RDP
Categoría (OWASP / CWE)	A05:2021 – Security Misconfiguration / CWE-200 (Information Exposure)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico Puntaje: 5.3
Evidencia	evidencias/escaneo/01_nmap_xmas_scan_999puertos.png, evidencias/escaneo/02_nmap_syn_scan_5000puertos.png
Herramienta utilizada	Nmap (Xmas scan -sX, SYN scan -sS)
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Bloquear o limitar a redes de confianza los servicios innecesarios expuestos (RDP, FTP, DNS); el bloqueo de ICMP por sí solo es insuficiente como medida de ocultamiento.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-07

ID del hallazgo	H-07
Sala	Nmap
Fase	☐ Reconocimiento ☐ Escaneo ☒ Enumeración ☐ Explotación ☐ Postexplotación
Descripción	El servicio FTP (puerto 21) permite login anónimo (código de respuesta FTP 230), confirmado con el script ftp-anon de Nmap. Esto permite a cualquier atacante no autenticado acceder potencialmente al contenido del servidor FTP.
Componente afectado	Servicio FTP (puerto 21)
Categoría (OWASP / CWE)	A01:2021 – Broken Access Control / CWE-287 (Improper Authentication)
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico Puntaje: 5.8
Evidencia	evidencias/escaneo/03_nmap_ftp_anon.png
Herramienta utilizada	Nmap (script ftp-anon)
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad

Salvaguarda propuesta	Deshabilitar el acceso anónimo en el servicio FTP y exigir autenticación para cualquier operación de lectura o escritura.
Riesgo residual tras aplicar	[X] Bajo [] Medio [] Alto

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	1	H-05
Alto	2	H-03, H-04
Medio	3	H-02, H-06, H-07
Bajo	1	H-01
Total	7	H-01 a H-07

Conclusión general: la evaluación sobre Basic Pentesting identificó una cadena de ataque completa, desde la exposición de información interna en un directorio web hasta el acceso total a las credenciales del sistema, mediante contraseñas débiles y permisos de archivos mal configurados. Ninguna de las fallas requirió vulnerabilidades sofisticadas: la combinación de configuraciones simples e incorrectas permitió comprometer el sistema por completo. En la sala de elección (Nmap), se confirmó que el bloqueo de ICMP no es una medida de seguridad suficiente por sí sola, y se identificó un servicio FTP con acceso anónimo habilitado. Se recomienda priorizar el fortalecimiento de la política de contraseñas, la revisión de permisos de archivos sensibles y la auditoría de servicios expuestos innecesariamente.

5. Post-pentesting: Recomendaciones

5.1 Recomendaciones técnicas (parches y configuraciones)

Prioridad	Hallazgo	Acción de remediación
1 - Crítica	H-05	No almacenar contraseñas en texto plano; rotar de inmediato las credenciales comprometidas
2 - Alta	H-04	Corregir permisos de /home/kay/.ssh/id_rsa a 600 y forzar passphrases robustas en todas las claves privadas
2 - Alta	H-03	Forzar política de contraseñas robustas, autenticación por clave pública en SSH e implementar fail2ban
3 - Media	H-02, H-06, H-07	Deshabilitar listados de directorio, revisar exposición de servicios (FTP anónimo, RDP) y retirar notas internas del entorno de producción
4 - Baja	H-01	Exponer solo los servicios estrictamente necesarios y filtrar SMB a redes de confianza

5.2 Recomendaciones administrativas (políticas y procesos)

- Establecer y auditar periódicamente una política de contraseñas robusta para todos los usuarios del sistema.
- Capacitar al personal sobre el manejo seguro de claves SSH y el riesgo de almacenar contraseñas en archivos de texto plano.

- Incorporar revisiones periódicas de configuración (hardening) de los servicios expuestos (Apache, SSH, SMB, FTP) como parte del mantenimiento regular.

6. Protocolo de contingencia

6.1 Escenario de falla

Un escaneo agresivo de puertos o un ataque de fuerza bruta sin límites de tasa contra los servicios SSH o FTP podría saturar el servicio o activar mecanismos de bloqueo automático, interrumpiendo el acceso legítimo de los administradores al servidor. De hecho, durante el escaneo Xmas inicial contra la sala Nmap se observó un bloqueo temporal (rate-limiting) del firewall inmediatamente después del escaneo agresivo.

6.2 Impacto sobre la continuidad del negocio

Una interrupción de los servicios web, SSH o FTP afectaría la operatoria diaria de INSECUR S.A. que depende de estos servicios, con una indisponibilidad estimada de entre 30 minutos y algunas horas según la causa y el método de recuperación disponible.

6.3 Plan de respuesta

- **Activación:** monitoreo de servicios (alertas de caída) y reportes de usuarios sobre indisponibilidad.
- **Contención (primeros 15 minutos):** aislar el servicio afectado, suspender tareas de red en curso y notificar al equipo técnico.
- **Recuperación:** restaurar el servicio desde backup o mediante reinicio controlado; verificar integridad antes de reponer en servicio.
- **Comunicación:** notificar a la dirección de INSECUR S.A. y, en el contexto académico, al docente.
- **Post-mortem:** documentar la causa raíz, las acciones tomadas y las mejoras a implementar para evitar su repetición.

6.4 RTO y RPO estimados

RTO (Recovery Time Objective)	2 horas
RPO (Recovery Point Objective)	24 horas (último backup diario)

7. Anexos

Anexo A — Bitácora de comandos

Archivo	Contenido
bitacora/_anteriores/bitacora_pentesting_fundamentals.md	Sala teórica Pentesting Fundamentals: metodología y fases del pentesting
bitacora/_anteriores/bitacora_basic_pentesting.md	Basic Pentesting completa: escaneo, enumeración web, explotación SSH y escalada a kay
bitacora/_anteriores/bitacora_nmap.md	Sala Nmap completa: técnicas de escaneo (Xmas, SYN, TCP Connect) y enumeración FTP

Anexo B — Capturas de pantalla

Nota: las capturas se conservan completas (sin recortar), ya que la cátedra pidió que se vea el usuario, la fecha y hora del sistema Kali y la IP objetivo en cada una.

Archivo	Hallazgo	Qué demuestra
evidencias/reconocimiento/salas_completadas_perfil.png	—	Perfil de TryHackMe con las 3 salas marcadas como completadas
evidencias/escaneo/01_basicpentesting_nmap.png	H-01	Escaneo inicial de puertos y servicios (Nmap)
evidencias/escaneo/02_development_listado.png	H-02	Gobuster descubre el directorio /development/ (Status 301)
evidencias/escaneo/03_dev_j_contenido.png	H-02	Contenido de dev.txt y j.txt descargado con wget
evidencias/escaneo/11_wireshark_tcp_connect_puerto80.png	—	3-way handshake TCP capturado con Wireshark (metodología TCP Connect scan)
evidencias/explotacion/04_hydra_login_jan_armando.png	H-03	Hydra encuentra la contraseña válida de jan
evidencias/explotacion/05_ssh_login_jan.png	H-03	Login SSH exitoso como jan
evidencias/explotacion/06_home_kay_listado.png	H-04	Listado de /home y /home/kay (hallazgo del usuario kay)
evidencias/explotacion/07_enumeracion_privileges.png	H-04	Enumeración de privilegios (sudo -, SUID, uname)
evidencias/explotacion/08_kay_ssh_private_key.png	H-04	Clave privada id_rsa de kay con permisos de lectura abiertos
evidencias/explotacion/09_scp_crack_kay_passphrase.png	H-05	Copia de la clave y crackeo de la passphrase con John the Ripper
evidencias/explotacion/10_pass_bak_final_password.png	H-05	Acceso como kay y contenido de pass.bak
evidencias/escaneo/01_nmap_xmas_scan_999puertos.png	H-06	Xmas scan: 999 puertos open filtered
evidencias/escaneo/02_nmap_syn_scan_5000puertos.png	H-06	SYN scan: 5 puertos abiertos (ftp, domain, http, msrpc, ms-wbt-server)

Archivo	Hallazgo	Qué demuestra
evidencias/escaneo/03_nmap_ftp_anon.png	H-07	Login FTP anónimo confirmado (código 230)

Anexo C — Hashes de las credenciales obtenidas (SHA-256)

Las credenciales encontradas durante la intervención no se publican en texto plano; se reporta únicamente su hash SHA-256 a modo de verificación.

Secreto	Sala	SHA-256
jan (contraseña SSH)	Basic Pentesting	9eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617
kay (passphrase id_rsa)	Basic Pentesting	873504f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08
kay (pass.bak - contraseña final)	Basic Pentesting	3ffd53ec80858f9ddcd75d69102724ab1bc1020855ff924227f618c4bfccf57

La sala Nmap (de elección) trabaja técnicas de escaneo y enumeración; no se obtuvo ninguna credencial ni flag en formato thm{...} durante su resolución, por lo que no aplica un hash adicional en este anexo.

Anexo D — Declaración ética firmada

Yo, Juan Manuel Maure Spinelli, DNI 44.904.602, declaro que todas las actividades descritas en este informe se realizaron dentro del alcance autorizado, en entornos controlados de TryHackMe y con fines exclusivamente académicos.

Juan Manuel Maure Spinelli

08/10/2026

Firma del estudiante

Fecha

8. Fuentes y bibliografía

- TryHackMe. Pentesting Fundamentals. <https://tryhackme.com/room/pentestingfundamentals>
- TryHackMe. Basic Pentesting. <https://tryhackme.com/room/basicpentestingjt>
- TryHackMe. Nmap. <https://tryhackme.com/room/furthernmap>
- OWASP Foundation. OWASP Top 10:2021. <https://owasp.org/Top10/>
- OWASP Foundation. Web Security Testing Guide (WSTG). <https://owasp.org/www-project-web-security-testing-guide/>
- The Penetration Testing Execution Standard (PTES). <http://www.pentest-standard.org/>
- FIRST.org. Common Vulnerability Scoring System (CVSS) v3.1. <https://www.first.org/cvss/>
- Anthropic. Claude (Sonnet 5), asistente de IA utilizado como apoyo en la organización de la bitácora, la redacción y el maquetado de este informe a partir de los comandos, resultados y capturas obtenidos por el autor. <https://claude.ai> — octubre de 2026.